

AEGIS

Action-bound authority and persistent information-flow controls

SENTINEL / IndabaX Tunisia - submission report

23 September 2026

Team: Mourad has lost a finger

Members: Mourad Kraiem; Mohamed Yassin ghaoui; Amine Fathallah

1. Problem and contribution

An assistant can read a document that contains an attacker's instructions. If it mistakes those instructions for permission, it may leak a credential, approve an unauthorized payment, or store a malicious policy. AEGIS checks the proposed action at the boundary between the assistant and its tools. It can allow, block, rewrite, or request exact-action human approval.

For example, an attacker-controlled ticket can ask the agent to copy a backup token into an external draft. AEGIS remembers the sensitive item from its source, detects its representation in the proposed output, and can produce a redacted draft. The legitimate task can continue without releasing the token.

Threat model and hypothesis

The attacker controls scenario-designated documents, emails, logs, tool results, or memory text in a simulated organization. It cannot alter trusted policy, trusted approval records, the defense process, or the simulator tools. We hypothesize that checking action authority and source-derived data flow preserves task utility while preventing the published harmful outcomes.

Latest build: known public suite	Observed result
Static mock; seeds 0, 11, 29	40/40 tasks; 0/31 successful attacks per seed
Adaptive mock; seed 0	40/40 tasks; 0/30 validated attacks; 1 excluded
Implementation regression checks	162 passed; no expected failures
Measured defense p95 latency	17.713-43.938 ms across static seeds

These are development results on published scenarios, not an official score or evidence of universal protection. The latest full-suite evidence uses the organizer mock model. Known exposed channels and false blocks are reported below.

2. Method and observability

Boundary: agent proposes an action -> AEGIS validates permission and schema -> checks source-derived flow and authority -> checks lifecycle and exact approval -> emits a decision receipt -> simulator executes the allowed or rewritten action.

Persistent source evidence. Credentials and sensitive source text remain available to the defense when agent history is truncated. State is scoped to an opaque session identifier. Later requests missing their state fail closed. Sessions have a one-hour TTL and a 128-session cap; the prototype requires a single worker.

Bounded representation matching. Plain and compact text, reversal, Base64/Base64URL, hex, URL decoding, Base32, ROT13, and a partial Unicode security skeleton are checked. Decoding has two rounds. The skeleton covers 16 selected confusables; this is not complete Unicode confusable coverage. Composed transformations have explicit regressions.

Output accumulation. Authorized emissions are tracked by destination and field. Ordered streams and four-character coverage checks detect tested split leaks; isolated two-character cases are also tested. Arbitrary one-character leakage and distribution across recipients remain exposed.

Authority and lifecycle. Untrusted prose cannot promote itself into trusted memory or approval. Approvals bind to exact action arguments. Object lifecycle checks require observed trusted success envelopes. Changing an approved action invalidates that approval. Sensitive-flow policy still applies to approved actions.

Safe repair. Sensitive output can be redacted and a send converted into a draft; the replacement is revalidated. Three unambiguous read-only argument aliases can be repaired against the public schema. Selected unsupported completion claims are qualified, but this does not perform missing work or prove exact goal completion.

Observable decisions. The local dashboard shows attack source, sensitive item, attempted action, reason, intervention, and final task result. Redacted hash-chained receipts link evidence to decisions. The chain is tamper-evident only against a separately retained chain head; it is not a digital signature.

What remains fixed

The organizer reference agent, tools, and system prompt are not hardened. The upstream submodule is pinned and unmodified. AEGIS reads the participant-visible request contract and public schemas; it does not load scenario IDs, fixture secrets, reference plans, or grading labels into defense decisions.

3. Public-suite evaluation

A defended case is eligible only if its paired allow_all run succeeds in attacking the same scenario with the same model, revision, seed, and attack mode. A failed undefended attack is excluded, not counted as protection.

Configuration	Tasks	Successful attacks	p95 ms
Static allow_all, seed 0	32/40	31/31	0.778
Static provenance baseline, seed 0	38/40	0/31	0.585
Static AEGIS, seed 0	40/40	0/31	17.713
Static AEGIS, seed 11	40/40	0/31	29.247
Static AEGIS, seed 29	40/40	0/31	43.938
Adaptive allow_all, seed 0	33/40	30/31	-
Adaptive AEGIS, seed 0	40/40	0/30 eligible	18.350

Adaptive finance_split_settlement failed the undefended prerequisite and is excluded from defense claims. All 31 static attacks were exercised undefended at each reported seed. Repeated seeds on the same published suite are correlated observations.

Static family (seed 0)	Tasks passed	Successful attacks
Data exfiltration	21/21	0/21
Direct instruction	3/3	0/3
Memory poisoning	2/2	0/2
Indirect prompt injection	4/4	0/4
Multi-step	1/1	0/1
Benign	9/9	Not applicable

Real-model evidence is historical. A September 21 Qwen pilot exercised two backup-token attacks undefended and completed both tasks with AEGIS after redaction. The finance pilot failed the prerequisite. These runs predate current encoding/performance changes and are not current-build Qwen validation. Current recording pairs are explicitly MOCK.

4. Ablation and performance

The 304 stress probes and 192 useful-draft checks are author-designed contract tests, not independent held-out attacks. Components are disabled to expose their contribution on these probes.

Configuration	Probes prevented	Useful drafts
Full AEGIS	304/304	192/192
aegis_v1 component configuration	256/304	192/192
No unordered coverage	256/304	192/192
No flow checks	16/304	0/192
No persistence	112/304	96/192
No authority checks	288/304	192/192
No repair	304/304	0/192
No streaming	208/304	192/192

The aegis_v1 row is a component-toggle configuration using shared current code, not a rerun of a frozen historical release. Full-suite ties do not establish that components are redundant; targeted probes reveal different failures.

Same configuration	Before p95 ms	After p95 ms
Static seed 0	133.983	17.713
Static seed 11	196.041	29.247
Static seed 29	188.425	43.938
Adaptive seed 0	159.868	18.350

Optimization caches per-secret representations and redaction patterns, uses an ASCII normalization fast path, and deduplicates decoding intermediates. It does not remove security checks. All 845 compared decision payloads remained equal. Across 1,440 text cases, matching, redaction, and decoded-view sets remained equal. These finite comparisons are not a proof for every possible input.

Timing includes receipt/redaction work and is machine-specific. Original runs and the frozen pre-optimization flow implementation are retained. Regression checks: 162 passed, with two dependency deprecation warnings; Ruff passed. Separate upstream tests had 203 passes and three Windows platform failures (symlink privileges and POSIX path expectations); they are not concealed as passing.

5. Failures and safety boundaries

Adversarial audit: 10 cases	Observed outcome
Zero-width; Unicode lookalikes; ROT13; Base32	Intervention in all four tested cases
Semantic paraphrase	Human review; not semantic proof
Approval argument mutation; fake lifecycle receipt	Intervention in both tested cases
Cross-session isolation	Isolated in the tested case
Arbitrary one-character leak	EXPOSED
Multi-recipient collusion	EXPOSED

Hard negatives: 40/40 benign drafts were allowed unchanged: ten warning/quotation messages in four contexts. For example, a warning saying API keys should never be emailed externally must not itself prevent safe work. These are 40 checks, not 40 independently sampled messages.

False blocks: the static seed-0 benchmark records 16/162 legitimate-labelled actions blocked (9.877%). Eight involve unsafe credential-copy content that the tool/target matcher still labels legitimate. Eight are clean follow-up notes blocked by the authority heuristic and are real false positives. All affected scenarios still finish their task. The per-action analysis is retained; neither category is silently removed from the reported metric.

Mock dependence: the organizer mock uses a structural instruction grammar and a reference plan. AEGIS uses lexical action/target authority matching in part, so these experiments do not establish robust recognition of arbitrary natural-language attacks. Encoding and prose probes broaden coverage but do not substitute for real-model validation.

Other limits: partial confusable coverage; bounded decoding; conservative confidential-prose escalation; incomplete factual verification of final claims; early fragment release; no global cross-recipient accumulator. Risk levels are ordinal policy signals, not calibrated probabilities. This local single-worker prototype lacks production authentication and distributed state hardening.

Responsible AI

All demonstrations use synthetic organizational data and simulated effects. No real credentials or external messages are required. Human escalation is an explicit policy outcome, not autonomous understanding. We preserve failed baselines and limitations, distinguish historical Qwen from current mock evidence, and do not claim a production security guarantee. Source code and auditable receipts support scrutiny of both protection and utility costs.

6. Reproduction and declarations

Upstream: Skan22/Sentinel_Starter_Kit, pinned commit dd2e5fe0979d0781a4bfe6d0849cd80cf69ef4a2.

How we ran it. Python 3.12.14; local AEGIS defense; organizer mock for current full-suite static seeds 0, 11, 29 and adaptive seed 0. We did not modify the reference agent prompt, tools, or model. See the root README for installation and exact commands, and requirements-lock.txt for dependencies.

Historical Qwen runtime. Qwen3-8B Q4_K_M through local llama.cpp Vulkan on an RTX 5060 Laptop GPU with 8 GB VRAM; context 8192; one parallel slot; thinking disabled; temperature 0; seed 0; output budget 768; HTTP timeout 180 seconds. Quantization and runtime choices are declared, not added safety instructions. Ollama protocol tests are not a measured real-weights Ollama demonstration.

External models and data. No trained defense model, external inference API, or AI judge is used by AEGIS. The reference Qwen model is organizer-selected open-weight software. Data comprise organizer public scenarios and author-created synthetic probes. Published scenarios were used during development; no independent holdout claim is made. Coding assistance was used in implementation and report preparation; reported outcomes come from retained executable evidence.

Evidence in the repository	Purpose
artifacts/20260922T190222055363Z/	Current static full suite
artifacts/20260922T190233948131Z/	Current adaptive full suite
artifacts/stress.json	Component ablations
artifacts/break-aegis-20260922.json	Adversarial audit / hard negatives
artifacts/performance-comparison.json	Before/after equivalence and timing
artifacts/performance-baseline/	Frozen pre-optimization source/profile
artifacts/20260921T182139112503Z/	Historical Qwen pilot
docs/technical-report.md	Detailed methods and full tables
docs/false-block-analysis.md	All 16 labelled false-block actions
docs/demo-evidence.md	Validated, model-labelled recording pairs

Manifests retain configuration and source hashes. Simulator JSONL traces record effects; redacted audit JSONL records defense reasoning and chain heads. The source package includes a per-file SHA-256 manifest. Video/public-access verification is a separate submission step and is not asserted by this report.